

Confidentiality, Integrity & Availability

Why this matters: Every security requirement in your career can be decomposed into CIA. When an attacker steals data, they break Confidentiality. When ransomware scrambles files, it breaks Integrity and Availability. When a pentester proves a flaw, they demonstrate a CIA violation. Start here.

The Triad

Pillar	Meaning	Breach example
Confidentiality	Only authorized parties can read data	Database exfiltration, shoulder surfing
Integrity	Data is accurate and unmodified	Tampered bank transfer, config change
Availability	Authorized users can access when needed	DDoS, ransomware lockout, disk failure

Gianni's complement: the extended models

Modern frameworks add more:

- Parkerian Hexad adds Authenticity, Utility, Possession
- DAD (Disclosure, Alteration, Destruction) is the attacker view of CIA
- DREAD / STRIDE are threat-modeling lenses (Microsoft) that map to CIA violations

Trade-offs

Security is never absolute. You choose:

- Confidentiality vs Availability – tighter encryption slows access

Integrity vs Usability – versioned immutable backups cost storage

Security vs Speed – MFA annoys users every login

A security architect's job is to find the right balance for the business's risk appetite – not to say "no" to everything.

Real example

An e-commerce breach: attacker uses SQL injection in the search bar (CIA Integrity of query) to dump the customer table (Confidentiality) – then a ransom note bricks the site (Availability). One injection broke all three pillars.

Takeaway: When someone describes an attack or control, name the CIA pillars it touches. This forces precision in every conversation.

[← Module start](#)

[Threat Modeling: The Disciplin...](#)